

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (scanner/NVD CVSS-weighted) · Generated 2026-07-11 · Model: `risk = 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Summary

Band	Count
CRITICAL	0
HIGH	5
MEDIUM	2
LOW	16

No dependency reaches the CRITICAL weighted-score threshold (≥ 8.0), and no dependency carries a CVE floor override this run. `log4j-core` and `jackson-databind` both hit the CVE-severity ceiling (10.0) but are held to HIGH by their moderate exposure/criticality — engineering judgement should still treat both as top-of-backlog given Log4Shell's active-exploitation status.

Ranked remediation backlog

#	Coordinate	Band	Risk	CVE sev.	Exposure	Criticality	Top CVE	Fix
1	org.apache.logging.log4j:log4j-core:2.14.1	HIGH	7.8	10.0	8.0	2.0	CVE-2021-44228 (Log4Shell)	2.15.0
2	com.fasterxml.jackson.core:jackson-databind:2.9.8	HIGH	7.8	10.0	8.0	2.0	CVE-2020-8840	2.9.10.3
3	com.fasterxml.jackson.core:jackson-core:2.9.8	HIGH	7.0	9.7	6.0	2.0	CVE-2025-52999	2.15.0
4	com.google.protobuf:protobuf-java:3.19.4	HIGH	6.7	9.0	6.0	2.0	CVE-2024-7254	3.25.5
5	com.google.guava:guava:24.1.1-jre	HIGH	6.3	7.6	7.0	2.0	CVE-2023-2976	32.0.0-android
6	commons-io:commons-io:2.4	MEDIUM	5.2	5.3	7.0	2.0	CVE-2021-29425	2.7
7	org.apache.commons:commons-lang3:3.4	MEDIUM	5.2	5.3	7.0	2.0	CVE-2025-48924	3.18.0
8	org.apache.logging.log4j:log4j-api:2.14.1	LOW	2.8	0.0	8.0	2.0	—	—
9	mysql:mysql-connector-java:8.0.30	LOW	2.8	0.0	8.0	2.0	— (GPL-2.0 license violation)	8.0.33
10	com.fasterxml.jackson.core:jackson-annotations:2.9.0	LOW	2.2	0.0	6.0	2.0	—	—

11–23	build/test tooling & pure-annotation transitives (jsr305, checker-compact-qual, error_prone_annotations, j2objc-annotations, animal-sniffer-annotations, junit-jupiter family, opentest4j, apiguardian-api)	LOW	1.1 – 1.9	0.0	3.0 – 5.0	1.0 – 2.0	—	—
-------	---	-----	-----------	-----	-----------	-----------	---	---

Full component scores and rationale for all 23 dependencies are in `depscan-risk-report.json`.

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted risk
log4j-core	10.0	8.0	2.0	7.8
jackson-databind	10.0	8.0	2.0	7.8
jackson-core	9.7	6.0	2.0	7.0
protobuf-java	9.0	6.0	2.0	6.7
guava	7.6	7.0	2.0	6.3
commons-io	5.3	7.0	2.0	5.2
commons-lang3	5.3	7.0	2.0	5.2

Business criticality defaults to 2/10 for every dependency in this run — only `log4j-core` / `log4j-api` have a located usage (`DiscountCalculator.java`, an internal pricing service, not an auth/payment/PII code path), and all other coordinates fall back to the documented default (`criticality_source: default`) because no import of them was found in `src/`.

Priority recommendations

- P0** — Upgrade `log4j-core` / `log4j-api` 2.14.1 → 2.15.0+ (ideally the latest 2.x line) to close Log4Shell (CVE-2021-44228, CVSS 10.0, actively exploited, CISA KEV-listed).
- P0** — Upgrade `jackson-databind` 2.9.8 → at least 2.9.10.8 (or the 2.12+/2.15+ line) — 55 known CVEs including 14 rated CRITICAL (9.8) gadget-chain deserialization RCEs.
- P1** — Upgrade `jackson-core` → 2.15.0+ and `protobuf-java` → 3.25.5 (transitive; bump via the parent `jackson-databind` / `mysql-connector-java` upgrades where possible).
- P1** — Upgrade `guava` 24.1.1-jre → a current 32.x/33.x release (major — review API surface).
- P2** — Routine bumps: `commons-io` → 2.14.0+, `commons-lang3` → 3.18.0+.
- P2** — Resolve the `mysql-connector-java` GPL-2.0-with-FOSS-exception license flag with legal/ licensing review (8.0.33 patch bump does not change the license).
- Out of scope for this stage** — the typosquatted `com.fastxml.jackson.core` coordinate and the untrusted HTTP mirror are supply-chain findings owned by `depscan-supplychain-audit`, not scored in this backlog.

Stage 3 status

All P0/P1/P2 items above (#1–#6) were auto-remediated on branch `fix/depscan-20260711-052154` — 73 of 74 CVE findings cleared, build/tests pass. Item #6 (`mysql-connector-java` license) is explicitly **not** resolved (patch bump doesn't change the license) and is tracked as a MAJOR_REVIEW follow-up issue. Item #7 remains Stage 4 scope. Full detail: `depscan-reports/CVE-Report.md` → "Remediation" section.

Machine-readable source: `depscan-risk-report.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 2.